

ENTERPRISE SECURITY ASSESSMENT LAB

API Security Evidence Documentation Report

DVGA GraphQL Lab Running Evidence

Professional Portfolio Edition - Authorized API Security Lab Evidence

Field	Details
Test Area	DVGA GraphQL lab
Result Type	GraphQL lab proof
Evidence Report File	14-dvga-graphql-lab-running-evidence-report.pdf
Testing Phase	GraphQL Lab Deployment
Tool / Component	DVGA / Browser
OWASP / Security Mapping	GraphQL Testing Preparation
Repository Path	02-api-security/reports/evidence/
Prepared For	GitHub recruiter portfolio documentation

This report documents one API Security evidence row as a standalone professional artifact. It includes the embedded screenshot, what it proves, the methodology context, command/workflow, sanitized output style, risk interpretation, remediation guidance, and publication redaction requirements.

1. Embedded Evidence Screenshot

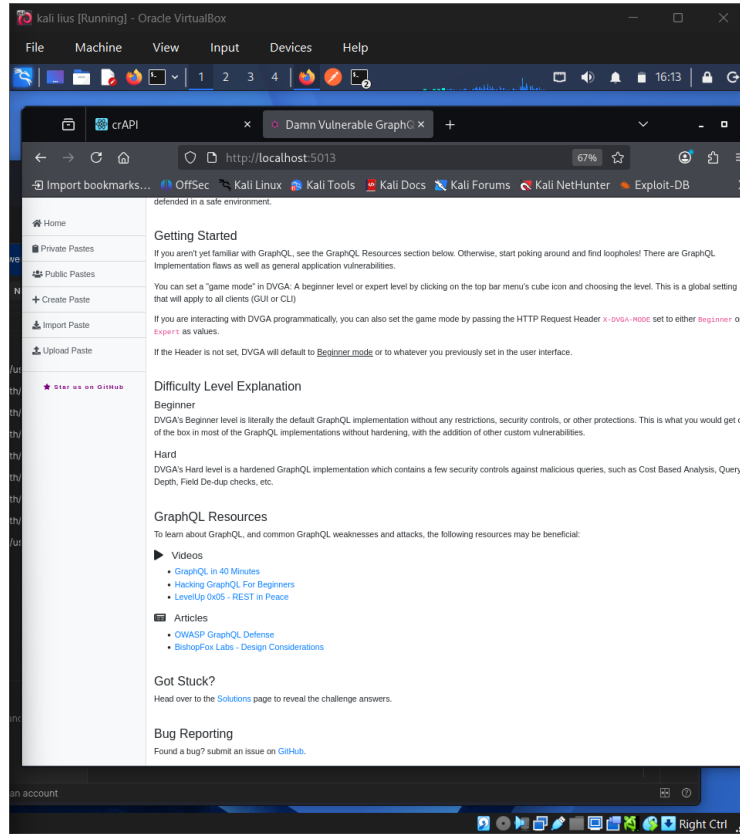


Figure 1 - Embedded screenshot evidence for: DVGA GraphQL lab

What this evidence proves

The evidence shows the DVGA GraphQL lab accessible in the browser. This establishes the GraphQL testing target as an authorized local lab.

Evidence handling note

The screenshot has been prepared for GitHub publication. Sensitive fields such as credentials, tokens, JWTs, cookies, personal data, host values, or other secrets are blurred or represented as redacted values where needed.

2. Assessment Context and Methodology Placement

Area	Value
Testing Phase	GraphQL Lab Deployment
Tool / Component	DVGA / Browser
Assessment Objective	Confirm that the DVGA GraphQL vulnerable lab is running and accessible before GraphQL security testing.
Result Type	GraphQL lab proof
OWASP / Security Mapping	GraphQL Testing Preparation

Why this evidence matters

GraphQL has a different attack surface from REST APIs. Before testing introspection, queries, and resolver-level access control, the lab target must be confirmed.

Command / workflow used

```
Start DVGA lab
Open browser to local GraphQL app
Verify UI and endpoint availability
Proceed to endpoint and schema checks
```

Sanitized output style

```
DVGA application page loaded
GraphQL target available
Local lab environment confirmed
```

3. Professional Interpretation

This evidence row should be interpreted as: **GraphQL lab proof**.

This is not a vulnerability. It proves the GraphQL lab was deployed. Exposing DVGA publicly would be dangerous because it is intentionally vulnerable.

Assessor notes

This provides the baseline evidence for later GraphQL endpoint and introspection tests.

How a recruiter or reviewer should read this evidence

The value of this evidence is not only the screenshot itself. The value is that it demonstrates a structured API security testing process: controlled lab setup, targeted testing, safe interpretation of results, and clear separation between confirmed vulnerabilities and controls that rejected attack attempts.

Important reporting distinction

This row is setup or workflow evidence. It supports the assessment chain but should not be described as a security finding by itself.

4. Risk, Impact, and Remediation Guidance

Risk perspective

This is not a vulnerability. It proves the GraphQL lab was deployed. Exposing DVGA publicly would be dangerous because it is intentionally vulnerable.

Recommended remediation / hardening actions

- Keep DVGA local-only.
- Stop the lab after testing.
- Do not expose vulnerable GraphQL labs to the internet.
- Document scope clearly.

Validation guidance after remediation

- Repeat the same test workflow after remediation and compare the response behaviour.
- Confirm that sensitive data is no longer exposed in raw API responses.
- Confirm that unauthorized requests return secure error responses such as 401 or 403 where appropriate.
- Confirm that security controls are enforced server-side, not only in the frontend or client collection.

5. GitHub Publication and Redaction Guidance

Sensitive values to redact before public upload

- Local user paths if visible.
- Any tokens or session values.
- Private hostnames.

General API evidence redaction checklist

- Blur JWT access tokens, bearer tokens, OAuth codes, cookies, and authorization headers.
- Blur email addresses, phone numbers, user IDs, vehicle IDs, order IDs, and private object identifiers.
- Do not upload Postman environment files containing live variables or secrets.
- Do not upload raw response exports containing personal data or secret-bearing values.
- Use placeholders such as , , and .

GitHub link format for 02-api-security/README.md

[DVGA GraphQL lab](./reports/evidence/14-dvga-graphql-lab-running-evidence-report.pdf)

Final classification

This PDF is suitable for a public GitHub portfolio only after the embedded screenshot has been reviewed and sensitive values are confirmed blurred or removed.